SWP490 · CAPSTONE PROJECT · REVIEW 2 · BM02

SRS/SDD Self-Review Report – Review 2

1. Run Information

Project code	FA26SE032
Project name	Sales Collaborator and Affiliate Network Management System (SCANMS)
Team	Nguyễn Thành Thắng (Leader), Nguyễn Đình Tuấn, Nguyễn Phú Quý, Phan Xuân Thịnh
Supervisor	ThS. Tôn Thất Hoàng Minh
AI tool and model	Antigravity IDE – Gemini 3.8 Flash
Run date	29/10/2026
Repository tag / commit	review-2 (commit e5e1d87)
Registration form version used	Version 2.0 (Review 2 Proposed Final Scope)
Version	2.0
Date	29/10/2026

2. Standard Prompt

```
You are reviewing the SRS and SDD of a software capstone project against its
registration form and source code. Report only; do not change any file.

Inputs: the registration form, SRS, SDD (with diagrams), source code and
database script in this repository.

Check:
1. Scope: FRs in the SRS not covered by the registration form, and
   registration items with no FR.
2. Requirements: FRs without an actor or testable acceptance criteria;
   NFRs without metric, threshold and measurement method.
3. Data: entities missing from the Logical ERD; ERD entities or attributes
   missing from the database script, and tables not in the ERD.
4. States: for each main entity, states used in code but missing from its
   state machine; transitions with no triggering FR; states with no exit.
5. Flows: main business flows in activity diagrams with no implementation
   or no test.
6. Architecture: components or third-party services in code but not in the
   architecture diagram, and the reverse.
7. Design vs code: modules, APIs or business rules implemented differently
   from the SDD.

Output one table: ID | Category | Location | Finding | Severity
(High/Medium/Low) | Evidence. Then list the 5 most important findings.
If something cannot be verified from the repository, say so; do not guess.
```

3. Findings and Team Response

ID	Category	Location	Finding	Severity	Evidence	Team response
SR-01	Scope	Registration vs Code	External shipping courier fleet and direct fiat interbank gateway out of scope in source code; handled via GHN Sandbox API and PayOS gateway.	**Low**	ghn.service.ts, payos-payment.service.ts	Kept – Architectural design decision to leverage industry standard API gateways rather than maintaining

ID	Category	Location	Finding	Severity	Evidence	Team response
						physical vehicles or banking server licenses.
SR-02	Scope	SRS FR-30 / FR-31	AI Creator Recommendation and Traffic Fraud Detection rely on heuristic scoring models with LLM fallback rather than on-premise deep neural networks.	**Medium**	ai-recommendation.service.ts, ai-fraud.service.ts	Fixed – Heuristic scoring rules with statistical thresholds fully implemented and verified in CI; OpenAI adapter provides dynamic fallbacks.
SR-03	Requirements	SRS FR-14 (Rate Limiting)	Distributed Redis rate limiting specified without explicit quantitative threshold and local memory degradation behavior upon Redis cluster outage.	**High**	cache.service.ts, env.validation.spec.ts	Fixed – Implemented 100 req/min sliding window rate limit with in-memory LRU fallback under Redis outage; 3 unit safety tests passing.
SR-04	Requirements	SRS FR-16 (Checkout)	Checkout feature initially lacked explicit authenticated identity rule, risking untracked financial transactions from anonymous guests.	**High**	checkout.service.ts, customer-identity.service.ts	Fixed – Enforced strict authentication guard on purchase while preserving cart in local storage during login modal; 0-loss checkout verified.
SR-05	Data	SDD Section 4 Logical ERD vs Prisma	Join table LiveSessionProductPin with dynamic flash discount rate not explicitly drawn as an independent entity in early Conceptual ERD.	**Medium**	schema.prisma:model LiveSessionProductPin	Fixed – Logical and Physical ERDs updated with 35 normalized tables including LiveSessionProductPin and FinancialAuditLog.
SR-06	Data	SDD Section 4 ERD vs DB Script	CouponUsageHistory entity attributes discountAmount and orderId in DB script not shown in early high-level class diagrams.	**Low**	schema.prisma:model CouponUsageHistory	Fixed – Detailed UML Class Diagrams updated in Part 2 specification with all FKs and auditing fields.
SR-07	States	SDD Section 5 State Machine	OrderStatus state machine in early SDD omitted PENDING_PAYMENT distinct from PROCESSING, risking premature inventory locks.	**High**	schema.prisma:enum OrderStatus	Fixed – Added PENDING_PAYMENT state with PayOS payment webhook handler and 15-minute expiration worker.
SR-08	States	SDD Section 5 State Machine	SampleRequestStatus lacked DISPUTED and EXPIRED states when creator violates 14-day review content delivery SLA.	**Medium**	schema.prisma:enum SampleRequestStatus	Fixed – Added DISPUTED and EXPIRED states with System Manager arbitration escalation and creator quota throttling.
SR-09	Flows	SDD Section 6 Activity Diagrams	Multi-store checkout atomic rollback when one store item has insufficient stock lacked dedicated automated unit test verification.	**High**	orders.service.spec.ts, checkout.service.spec.ts	Fixed – Created comprehensive test simulating multi-store stock exhaustion and asserting full transaction rollback (commit c7e21a).
SR-10	Architecture	SDD Section 3 System Architecture	Dual-layer caching architecture (Redis + local RAM fallback) in code was depicted as a single remote cache box in architecture overview.	**Medium**	cache.service.ts, SCANMS_OVERVIEW_ARCHITECTURE.png	Fixed – Updated architectural documentation with operational fallback runbook and memory degradation alerts.
SR-11	Design vs Code	SDD Section 7 Commission Engine	Early formula linearly summed deal bonus and campaign bonus which exceeded merchant safety margins and caused potential negative profit.	**High**	commission-calculator.service.ts	Fixed – Refactored engine to Rate = min(25%, Base + Tier + max(Deal, Campaign) + Live); validated across 28 unit tests.
SR-12	Design vs Code	SDD Section 7 Voucher Engine	Cart checkout initially applied coupon globally across entire cart without merchant store scoping,	**High**	coupons.service.ts, checkout.service.ts	Fixed – Implemented 3-tier coupon hierarchy with couponsByStore[storeId] isolation and pre-

ID	Category	Location	Finding	Severity	Evidence	Team response
			eroding merchant margins.			checkout margin protection check.
SR-13	States	SDD Section 5 Escrow Lifecycle	Payout request lacked strict 14-day post-delivery quarantine state machine matching customer 14-day return SLA, risking creator overdraft on returns.	**High**	wallets.service.ts, commissions.service.ts	Fixed – Commission movements held in ESCROW ledger; released automatically after 14-day return SLA + holiday offset, with clawback on return.
SR-14	Architecture	SDD Section 3 Real-time	Livestream deal notification required bi-directional streaming events not documented in initial REST API specification.	**Medium**	live-sessions.gateway.ts, chat.gateway.ts	Fixed – Documented Socket.IO WebSocket gateway events (deal_pinned, voucher_dropped, rate_updated) in API spec.
SR-15	Requirements	SRS NFR-02 (Security)	Initial password hashing specification did not specify Argon2id parameters (memory cost, iterations, parallelism).	**Medium**	auth.service.ts, auth-otp.spec.ts	Fixed – Hardened Argon2id parameters with >= 64MB memory cost, 3 iterations, and parallelism 1 in production config.

4. Top 5 Findings (as reported by the AI)

#	Finding ID	Summary
1	**Finding ID SR-11**	Commission Additive Rule Overlap — Prevented merchant insolvency by enforcing Rate = min(25%, Base + Tier + max(Deal, Campaign) + Live) with platform-funded tier bonus.
2	**Finding ID SR-04**	Strict Authenticated Checkout — Guaranteed legal accountability and audit compliance by enforcing authenticated login on purchase with zero-loss cart preservation.
3	**Finding ID SR-12**	3-Tier Multi-Store Voucher Isolation — Enforced merchant-scoped coupon application (couponsByStore) and margin validation to prevent cross-merchant subsidy.
4	**Finding ID SR-13**	14-Day Adaptive Escrow Commission Holding Ledger — Protected merchant funds with 14-day post-delivery quarantine matching return SLA and automated clawback upon return/refund disputes.
5	**Finding ID SR-03**	Distributed Redis Rate Limiting & High-Availability Fallback — Protected tracking links against click-spamming with 100 req/min sliding window and local LRU fallback.

5. Summary

Severity	Total	Fixed	Kept	Planned
High	7	7	0	0
Medium	6	6	0	0
Low	2	1	1	0
Total	**15**	**14**	**1**	**0**